

C05- ASSESSMENT TOOL -1

NAME:S.Dhivyasri

REG NO.:192511246

COURSE :Cryptography and network security

COURSE CODE :CSA5113

1.A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Answer:

The organization should first identify all legacy systems that cannot support modern TLS versions. The preferred solution is to upgrade or replace these systems so that they support TLS 1.2 or TLS 1.3. TLS 1.3 should be preferred because it provides stronger security and removes several outdated cryptographic mechanisms.

If immediate replacement is not possible, a secure reverse proxy or TLS gateway can be placed between the legacy systems and external users. The gateway can accept modern TLS connections from customers and securely communicate with the legacy backend through a controlled internal connection. This prevents external clients from directly using old SSL versions.

The organization should disable SSL 2.0, SSL 3.0, TLS 1.0, and TLS 1.1 on public-facing systems wherever possible. Only strong cipher suites and secure cryptographic algorithms should be enabled. Digital certificates should be issued by trusted Certificate Authorities and should be regularly renewed and monitored.

Network segmentation should also be implemented so that legacy systems are isolated from the public Internet. Firewalls and access-control rules should restrict communication between the legacy systems and other parts of the network. Continuous monitoring should be used to detect unauthorized or insecure connections.

The organization should also develop a migration plan to completely remove legacy SSL support. Regular vulnerability assessments and security testing should be performed to ensure that no outdated protocols remain exposed.

Therefore, the best solution is to use TLS 1.3 or TLS 1.2 for all external web transactions, isolate legacy systems, and use a secure TLS gateway or reverse proxy as a temporary bridge where upgrades are not immediately possible. This approach protects sensitive financial transactions while allowing the organization to gradually replace its outdated systems.

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Answer:

TLS protects the communication channel between the customer's browser and the e-commerce server. It provides confidentiality, integrity, and authentication during data transmission. TLS is widely supported by modern browsers, web servers, mobile applications, and payment systems. It is also relatively simple to deploy and maintain.

SET provides additional payment-specific security. It uses digital certificates to authenticate the customer and merchant and uses digital signatures to protect transaction information. SET can also separate payment information from order information, reducing the exposure of card details to the merchant. However, SET requires certificate management for participants and is more complex to implement.

Comparison:

TLS:

- Protects the communication channel between client and server.
- Provides encryption, integrity, and server authentication.
- Widely supported by modern web technologies.
- Easier to implement and maintain.

- Provides good performance and scalability.
- Does not by itself provide end-to-end payment-specific protection.

SET:

- Specifically designed for secure electronic payment transactions.
- Uses digital certificates and digital signatures.
- Provides stronger payment-specific authentication.
- Can protect card information from unnecessary exposure to the merchant.
- More complex to deploy and manage.
- Requires certificate infrastructure and greater coordination between customers, merchants, and payment providers.
- Has limited adoption compared with modern payment technologies.

For a modern e-commerce platform, continuing with TLS is generally the better decision. The platform should use current TLS versions, strong cipher suites, properly managed certificates, and secure payment gateways. Payment card information should preferably be handled by a trusted payment processor rather than stored directly by the e-commerce platform.

SET may provide strong security, but its additional complexity and limited adoption make it impractical for most modern e-commerce systems. Modern payment systems generally use TLS together with secure payment gateways, tokenization, and additional authentication mechanisms.

Therefore, the e-commerce platform should not replace its existing TLS infrastructure with SET. It should continue using modern TLS

and strengthen its payment architecture through secure payment gateways, tokenization, strong authentication, and proper certificate management. This provides strong security while maintaining better usability, scalability, compatibility, and lower operational complexity.

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Answer:

First, infected systems should be isolated from the corporate network immediately. Network access should be blocked or restricted to prevent the malware from spreading to other computers. Critical systems should be segmented into separate network zones using firewalls, VLANs, and access-control policies. Unnecessary ports and network services should also be disabled.

The organization should identify the source and extent of the infection using endpoint security tools, network monitoring, firewall logs, and security event logs. Infected systems should be scanned using updated anti-malware and endpoint detection and response tools. Malware samples and indicators such as malicious files, IP addresses, domains, and processes should be identified and blocked throughout the network.

All operating systems, applications, servers, and network devices should be regularly patched. Automatic security updates should be enabled wherever possible. Vulnerability scanning should be performed regularly to identify systems that are exposed to known vulnerabilities.

Endpoint protection should be deployed on all computers and servers. Modern endpoint security solutions can detect suspicious processes, unauthorized software, unusual network activity, and malware

behavior. Application allowlisting can also be used on critical systems to prevent unauthorized programs from executing.

Network segmentation and the principle of least privilege should be implemented to limit the ability of malware to move between systems. Users and applications should receive only the access permissions they require. Internal systems should not have unrestricted access to one another.

Firewalls and intrusion detection or prevention systems should monitor internal as well as external traffic. Unusual scanning activity, repeated connection attempts, and suspicious network traffic should trigger alerts or automatic blocking.

Regular backups should be maintained for critical systems and stored separately from production systems. Backups should be tested regularly so that infected systems can be restored safely after an attack.

The organization should also establish an incident response procedure covering identification, isolation, eradication, recovery, and post-incident analysis. Employees should receive security awareness training, although user training alone is not sufficient because the malware is spreading without user interaction.

Therefore, the recommended strategy is to immediately isolate infected systems, segment the network, block malicious traffic, identify and remove the malware, patch vulnerable systems, deploy endpoint protection, restrict network access, monitor network activity, and maintain secure backups. Combining these measures will contain the current infection and reduce the possibility of future rapid malware outbreaks.

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Answer:

The recommended architecture should use multiple security zones, including the Internet, a DMZ, the internal network, and restricted network segments. The Internet-facing firewall should be placed at the network perimeter to inspect incoming and outgoing traffic. Only necessary services such as web, email, and VPN connections should be permitted.

A DMZ (Demilitarized Zone) should be created for publicly accessible servers such as web servers, DNS servers, and email servers. These servers should be separated from the internal network so that compromise of a public server does not provide direct access to internal systems.

A second internal firewall should be deployed between the DMZ and the internal network. It should allow only specifically authorized traffic between the DMZ and internal systems. A default-deny policy should be used, allowing only required connections.

To protect against insider attacks, the internal network should be divided into separate security zones using network segmentation, VLANs, and internal firewalls. Sensitive departments and critical resources such as finance databases, customer information, and servers should be placed in restricted segments. Access should be based on the principle of least privilege.

The firewall should use stateful packet inspection and, where possible, next-generation firewall features such as intrusion prevention, application control, malware detection, and URL filtering. Firewall rules should be regularly reviewed and unnecessary rules should be removed.

Remote users should access the corporate network through a secure VPN with strong authentication. Administrative access to firewalls and critical systems should require multi-factor authentication and should be restricted to authorized administrators.

All firewall activities should be logged and monitored. Intrusion detection and prevention systems can be integrated with the firewall to detect suspicious traffic, unauthorized access attempts, port scanning, and other attacks. Security logs should be regularly analyzed to identify potential insider and external threats.

A suitable architecture can be represented as:

Internet → Perimeter Firewall → DMZ → Internal Firewall →
Internal Network → Segmented Sensitive Networks

Therefore, a multi-layered firewall architecture with a perimeter firewall, DMZ, internal firewall, network segmentation, strict access-control rules, VPN security, continuous monitoring, and centralized logging provides effective protection against both external threats and insider attacks. This defense-in-depth approach limits unauthorized access and reduces the impact of a successful attack.

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

ANSWER:

First, the organization should tune IDS/IPS detection rules based on the normal behavior of the network. Unnecessary or outdated signatures should be disabled, while important rules should be prioritized. Rules should be regularly updated to detect new threats.

The organization should use a combination of signature-based and behavior-based detection. Signature-based detection is effective for

known attacks, while behavior-based detection can identify unusual activities and previously unknown threats. Machine learning can also be used to identify abnormal network behavior and improve detection accuracy.

Network segmentation should be implemented so that monitoring can be customized for different network zones. Critical servers, databases, user networks, and guest networks can have different security policies. This reduces irrelevant alerts and allows the IDS/IPS to focus on high-risk traffic.

Alert severity levels should be introduced. Critical alerts such as confirmed malware activity, unauthorized access, and exploitation attempts should receive the highest priority. Low-risk events can be logged without generating immediate notifications. Similar alerts should also be correlated and grouped into a single incident to prevent security teams from receiving hundreds of duplicate alerts.

The IDS/IPS should be integrated with a Security Information and Event Management (SIEM) system. The SIEM can correlate IDS alerts with firewall, endpoint, authentication, and server logs. This provides additional context and helps determine whether an alert represents a genuine attack.

A feedback and tuning process should also be established. Security administrators should regularly review false positives and adjust detection rules accordingly. Whitelisting can be used carefully for trusted applications, servers, and known network activity, but it should not be applied too broadly because it can allow malicious activity to bypass detection.

For high-confidence threats, the IPS should automatically block malicious traffic. For uncertain events, the system should generate an alert for security-team investigation rather than automatically blocking legitimate traffic.

The optimized architecture can be represented as:

Internet → Firewall → IDS/IPS → Network Segmentation → Internal Systems → SIEM → Security Team

Therefore, the enterprise should implement a tuned and layered IDS/IPS solution using updated signatures, behavior-based detection, network segmentation, alert prioritization, event correlation, SIEM integration, and continuous rule tuning. This approach significantly reduces false positives and alert fatigue while allowing security teams to concentrate on genuine and high-priority threats.